Auditoría ApiProtection — WSRestApiHelp

Documento de respuesta formal a auditoría de conectividad y seguridad de accesos

API en alcance: `/outer/wsrestapihelp` (WSRestApiHelp / Ajustadores HN Backend)

Fuente de inventario: `ApiProtection_Endpoints.csv` · Origin: API Discovery · Status: PASSIVE

Cruce técnico: repositorio `AjustadoresHN_Backend` (controllers .NET Framework 4.8)

Fecha de análisis: 10 de septiembre de 2026

Alcance: se excluyen deliberadamente WebRestApi360, VTS LeadLanding, CAM ValidaDocumentos y patrones wildcard genéricos

19	5	7	58
ENDPOINTS HELP EN CSV	RIESGO CRÍTICO	RIESGO ALTO	FILAS TOTALES CSV (TODAS LAS APIS)

> **Hallazgo principal (código de aplicación)**
>
> En `ProveedorController` el atributo `[Authorize]` está comentado (`//[Authorize]`). Los endpoints GET descubiertos como *UNLIMITED* (listados de atenciones, expediente, GPS, cache de cliente, etc.) concentran el mayor riesgo del inventario: superficie descubierta sin rate limit observado en perímetro, más datos sensibles, más ausencia de autenticación a nivel de controlador.

1. Interpretación del inventario ApiProtection

Las filas del CSV aparecen con estado **PASSIVE** y métodos marcados como *** (UNLIMITED)**. En el contexto de discovery/protección de API, esto indica que sobre esos paths no se observaron controles activos de protección (rate limiting, bot management o reglas equivalentes) en el perímetro evaluado.

Importante: "PASSIVE / UNLIMITED" no significa por sí solo que el endpoint esté diseñado de forma insegura, pero sí que la superficie fue descubierta y no presenta límites visibles en la capa de protección externa. El riesgo real se confirma al cruzar ese inventario con la autenticación y autorización implementadas en el código.

2. APIs descartadas en este análisis

El documento mezcló varias APIs. Para esta respuesta formal solo aplica WSRestApiHelp.

API mezclada en el CSV	Endpoints (aprox.)	Motivo de exclusión
WebRestApi360	35	Citas, clínicas, sesión, pagos — fuera de alcance HELP
VTS LeadLanding	2	Landing / leads — otra aplicación
CAM ValidaDocumentos	1	Validación de documentos — otro dominio
Wildcard `/outer/{_1}/api/{_3}/{_4}`	1	Patrón genérico de discovery, no endpoint HELP específico

3. Inventario HELP: CSV × código

Sensibilidad y riesgo asignados por cruce con controllers actuales. Distribución: crítico 5 · alto 7 · medio 4 · bajo 3.

Endpoint	Methods (CSV)	Auth en código	Datos	Riesgo	Nota
/api/login/autenticacion	OPTIONS (scan) · POST real	AllowAnonymous (esperado)	Credenciales	MEDIUM	Login público; requiere rate limit / lockout (scan: UNLIMITED).
/api/login/getappversion	OPTIONS (scan) · GET real	AllowAnonymous	Baja	LOW	Metadato de versión; OPTIONS sin límite observado.

Endpoint	Methods (CSV)	Auth en código	Datos	Riesgo	Nota
/api/proveedor/obtenermisatenciones	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO en ProveedorController	Expedientes / PII	CRITICAL	Lista atenciones por IdProveedorAgente; sin auth de controlador = IDOR potencial.
/api/proveedor/obtenermisatencionesactivas	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO	Expedientes / PII	CRITICAL	Misma exposición que listado historial.
/api/proveedor/obtenerdatosexpedientes	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO	Expediente completo / PII / vehículo	CRITICAL	Datos ricos por IdAtencion; alto impacto si se enumera.
/api/proveedor/obtenerdatosdeatencion	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO	Atención / PII	CRITICAL	Lectura de atención sin auth a nivel controlador.
/api/proveedor/obtenercachecliente	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO	Cache cliente	HIGH	Datos de cliente en caché expuestos en discovery.
/api/proveedor/listadoajustadores	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO	Directorio interno	HIGH	Enumeración de ajustadores.
/api/proveedor/vectorgpsatencion	GET, OPTIONS UNLIMITED	[Authorize] COMENTADO	Ubicación GPS	HIGH	Trayectoria/ubicación de atención.
/api/proveedor/actualizarcordenadasajustador	OPTIONS (scan)	[Authorize] COMENTADO	GPS / tracking	HIGH	Escritura de coordenadas; método real no rate-limited en scan.
/api/proveedor/insertarcoordenadasatencionagenteproveedor	OPTIONS (scan)	[Authorize] COMENTADO	GPS	HIGH	Inserción de coordenadas de atención.
/api/proveedor/actualizalogatencion	OPTIONS (scan)	[Authorize] COMENTADO	Estado atención	MEDIUM	Mutación de log de atención.
/api/proveedor/listafotografiasfirmasatencion	OPTIONS (scan)	[Authorize] COMENTADO	Imágenes / firmas	HIGH	Metadatos/URLs de evidencias del siniestro.
/api/proveedor/subirfirmas	OPTIONS (scan)	[Authorize] COMENTADO	Firmas documentales	HIGH	Upload de firmas; sin límite en discovery.
/api/proveedor/tokenpushonesignal	OPTIONS (scan)	[Authorize] COMENTADO	Tokens push	MEDIUM	Registro de device tokens.
/api/proveedor/obtenerfiniquito	OPTIONS (scan)	No hallado como Route exacta en código actual	Financiero / finiquito	MEDIUM	Aparece en discovery; validar si es alias legacy o endpoint removido.
/api/seleccionmultiple/tipodefotografia	GET, OPTIONS UNLIMITED	[Authorize] activo	Catálogo	LOW	Catálogo; OPTIONS puede ser preflight CORS sin auth.
/api/seleccionmultiple/tipodelicencia	GET, OPTIONS UNLIMITED	[Authorize] activo	Catálogo	LOW	Catálogo; GET debería exigir JWT si el filtro aplica.
/api/ficohsahn/valida_lista_coberturas	OPTIONS (scan)	[Authorize] activo (FicohsaHN)	Coberturas / póliza	MEDIUM	Puente a Interamericana; sensible si se llama sin JWT efectivo.

4. Conclusiones de auditoría

1. El inventario ApiProtection confirma **superficie descubierta sin límites de tasa observados** sobre paths de HELP, incluyendo login y operaciones de lectura de expediente.
2. El cruce con código identifica una **brecha de control de acceso a nivel aplicación** en el controlador de Proveedor (`[Authorize]` deshabilitado), que eleva a crítico varios GETs con datos personales, de póliza/vehículo y telemetría GPS.
3. Controllers como `FicohsaHN` y `SeleccionMultiple` sí mantienen `[Authorize]`; el riesgo no es uniforme en toda la API, sino concentrado en Proveedor (y superficies anónimas esperadas como Login).
4. El CSV **no cubre endpoints recientes** (p. ej. búsqueda de atenciones, validación BPM, carga de reclamo). Se recomienda re-escaneo tras publicación para cerrar el gap discovery vs superficie real.

5. Plan de remediación recomendado (prioridad)

1. Acceso

- Reactivar `[Authorize]` en `ProveedorController`.
- Auditar `AllowAnonymous` (Login, Cliente, DescargarAudienciaIcs).
- Validar JWT en gateway + API (doble capa).
- Autorización por recurso (agente dueño de la atención) para mitigar IDOR.

2. Conectividad / perímetro

- Rate limit en login y GETs de expediente/listados.
- Restringir OPTIONS/CORS al origen de la app móvil/portal.
- Activar reglas ApiProtection (dejar de operar solo en PASSIVE).

3. Datos

- Minimizar campos PII en listados.
- Extender auditoría/logging a lecturas sensibles (además de logs BPM existentes).
- Revisar uploads (firmas/fotos) y tokens push.

4. Cobertura del inventario

- Re-escanear solo `/outer/wsrestapihelp`.
- Incluir endpoints nuevos no presentes en el CSV actual.
- Validar el path `obtenerfiniquito` (legacy vs removido).

> **Posición técnica respecto a modernización (.NET 10)**
>
> Migrar a .NET 10 / ASP.NET Core es recomendable como modernización de mediano plazo (mejor piso de seguridad nativa, rate limiting, secrets, middleware).
>
> **No sustituye**
>
> la remediación inmediata en .NET Framework 4.8: el hallazgo crítico de acceso se corrige reactivando y endureciendo autorización ahora. Estimación orientativa de migración completa: del orden de 3–5 meses para una entrega sólida (EF/EDMX, clientes SOAP Ficohsa, pruebas y despliegue); remediación de seguridad en Framework: del orden de 1–3 semanas.

6. Próximo paso propuesto

Priorizar: (1) reactivar `[Authorize]` en Proveedor, (2) rate limit de los GETs críticos del CSV, (3) re-ejecutar ApiProtection únicamente sobre `/outer/wsrestapihelp`, y (4) documentar evidencias de cierre para auditoría.

Documento generado a partir del análisis técnico ApiProtection × código WSRestApiHelp.
Clasificación sugerida: uso interno / respuesta a auditoría de seguridad.
No incluye secretos ni credenciales. Branch de referencia de trabajo reciente: `feature/bpm-validacion-y-listados` en `https://github.com/mcclellanDev/AjustadoresHN_Backend`.